

Alexandra Dones

March 9, 2026

Assignment 4

Assignment Overview:

The goal of this assignment is to improve your machine's DISA STIG score. This task involves researching remediation steps for Category (CAT) 1, 2, and 3 findings. The final deliverable will be a report of your selected findings including screenshots of your tailored scans. Further details are included below.

Main Tasks:

This project will encompass the following tasks:

1. Research the findings found from your previous DISA STIG scan results.
2. Select a minimum of 5 findings from each of the Categories. (Minimum of 15 total findings)
3. Tailor the DISA STIG rules for the SCC scan tool to only include the rules for your chosen findings.
4. Remediate all you chosen findings and rescan until your results reach 100% compliance.
5. Create a report with screenshots of your results from the scans performed. Include information about your experience remediating the findings.

HIGH SEVERITY (CAT I)

SCC Report Viewer [file:///home/adones/SCC/Sessions/2026-02-18_213956/Results/SCAP/LOCALHOST_SCC-5.14_2026-02-18_213956_All-Settings... x

NavigationSearch

BackForwardReloadQ Search<>Match Case0 of 0

Results: High Severity (CAT I)

Automated Checks

- o V-257777 - RHEL 9 must be a vendor-supported release. - Fail
- o V-257784 - The systemd Ctrl-Alt-Delete burst key sequence in RHEL 9 must be disabled. - Fail
- o V-257785 - The x86 Ctrl-Alt-Delete key sequence must be disabled on RHEL 9. - Fail
- o V-257820 - RHEL 9 must check the GPG signature of software packages originating from external software repositories before installation. - Pass
- o V-257821 - RHEL 9 must check the GPG signature of locally installed software packages before installation. - Fail
- o V-257822 - RHEL 9 must have GPG signature verification enabled for all software repositories. - Pass
- o V-257826 - RHEL 9 must not have a File Transfer Protocol (FTP) server package installed. - Pass
- o V-257835 - The Trivial File Transfer Protocol (TFTP) server must not be installed unless it is required, and if required, the RHEL 9 TFTP daemon must be configured to operate in secure mode. - Not Applicable
- o V-257955 - There must be no .shosts.equiv files on RHEL 9. - Pass
- o V-257956 - There must be no .shosts files on RHEL 9. - Pass
- o V-257984 - RHEL 9 SSHD must not allow blank passwords. - Fail
- o V-257986 - RHEL 9 must enable the Pluggable Authentication Module (PAM) interface for SSHD. - Pass
- o V-258018 - RHEL 9 must not allow unattended or automatic logon via the graphical user interface. - Fail
- o V-258059 - The root account must be the only account having unrestricted access to RHEL 9 system. - Pass
- o V-258078 - RHEL 9 must use a Linux Security Module configured to enforce limits on system services. - Pass
- o V-258094 - RHEL 9 must not allow blank or null passwords. - Fail
- o V-258230 - RHEL 9 must enable FIPS mode. - Fail
- o V-258236 - RHEL 9 cryptographic policy must not be overridden. - Fail

Manual Checks

- o V-257789 - RHEL 9 must require a unique superusers name upon booting into single-user and maintenance modes. - Not Checked
- o V-257879 - RHEL 9 local disk partitions must implement cryptographic mechanisms to prevent unauthorized disclosure or modification of all information that requires at rest protection. - Not Checked

SCC Report Viewer [file:///home/adones/SCC/Sessions/2026-03-09_231903/Results/SCAP/LOCALHOST_SCC-5.14_2026-03-09_231903_All-Settings_RHEL_9_STIG-002.007.011.html] x

NavigationSearch

BackForwardReloadQ Search<>Match Case0 of 0

Key Issuer: C=US, O=U.S. Government, OU=DoD, OU=PKI, CN=DOD ID CA-71

Key Validation Dates: Feb 18 00:00:00 2025 GMT - Feb 17 23:59:59 2028 GMT

Results: High Severity (CAT I)

Automated Checks

- o V-257777 - RHEL 9 must be a vendor-supported release. - Not Selected
- o V-257784 - The systemd Ctrl-Alt-Delete burst key sequence in RHEL 9 must be disabled. - Not Selected
- o V-257785 - The x86 Ctrl-Alt-Delete key sequence must be disabled on RHEL 9. - Not Selected
- o V-257820 - RHEL 9 must check the GPG signature of software packages originating from external software repositories before installation. - Not Selected
- o V-257821 - RHEL 9 must check the GPG signature of locally installed software packages before installation. - Not Selected
- o V-257822 - RHEL 9 must have GPG signature verification enabled for all software repositories. - Not Selected
- o V-257826 - RHEL 9 must not have a File Transfer Protocol (FTP) server package installed. - Not Selected
- o V-257835 - The Trivial File Transfer Protocol (TFTP) server must not be installed unless it is required, and if required, the RHEL 9 TFTP daemon must be configured to operate in secure mode. - Not Selected
- o V-257955 - There must be no .shosts.equiv files on RHEL 9. - Not Selected
- o V-257956 - There must be no .shosts files on RHEL 9. - Not Selected
- o V-257984 - RHEL 9 SSHD must not allow blank passwords. - Pass
- o V-257986 - RHEL 9 must enable the Pluggable Authentication Module (PAM) interface for SSHD. - Not Selected
- o V-258018 - RHEL 9 must not allow unattended or automatic logon via the graphical user interface. - Pass
- o V-258059 - The root account must be the only account having unrestricted access to RHEL 9 system. - Not Selected
- o V-258078 - RHEL 9 must use a Linux Security Module configured to enforce limits on system services. - Not Selected
- o V-258094 - RHEL 9 must not allow blank or null passwords. - Pass
- o V-258230 - RHEL 9 must enable FIPS mode. - Pass
- o V-258236 - RHEL 9 cryptographic policy must not be overridden. - Pass

Manual Checks

- o V-257789 - RHEL 9 must require a unique superusers name upon booting into single-user and maintenance modes. - Not Selected
- o V-257879 - RHEL 9 local disk partitions must implement cryptographic mechanisms to prevent unauthorized disclosure or modification of all information that requires at rest protection. - Not Selected

Results: Medium Severity (CAT II)

Automated Checks

MEDIUM SEVERITY (CAT II)

Results: Medium Severity (CAT II)

Automated Checks

- o V-257781 - The graphical display manager must not be the default target on RHEL 9 unless approved. - Fail
- o V-257783 - RHEL 9 systemd-journald service must be enabled. - Pass
- o V-257786 - RHEL 9 debug-shell systemd service must be disabled. - Fail
- o V-257787 - RHEL 9 must require a boot loader superuser password. - Fail
- o V-257788 - RHEL 9 must disable the ability of systemd to spawn an interactive boot process. - Pass
- o V-257790 - RHEL 9 /boot/grub2/grub.cfg file must be group-owned by root. - Pass
- o V-257791 - RHEL 9 /boot/grub2/grub.cfg file must be owned by root. - Pass
- o V-257792 - RHEL 9 must disable virtual system calls. - Fail
- o V-257793 - RHEL 9 must clear the page allocator to prevent use-after-free attacks. - Fail
- o V-257794 - RHEL 9 must clear memory when it is freed to prevent use-after-free attacks. - Fail
- o V-257797 - RHEL 9 must restrict access to the kernel message buffer. - Fail
- o V-257798 - RHEL 9 must prevent kernel profiling by nonprivileged users. - Pass
- o V-257799 - RHEL 9 must prevent the loading of a new kernel for later execution. - Fail
- o V-257800 - RHEL 9 must restrict exposed kernel pointer addresses access. - Pass
- o V-257801 - RHEL 9 must enable kernel parameters to enforce discretionary access control (DAC) on hardlinks. - Pass
- o V-257802 - RHEL 9 must enable kernel parameters to enforce discretionary access (DAC) control on symlinks. - Pass
- o V-257803 - RHEL 9 must disable the kernel.core_pattern. - Fail
- o V-257804 - RHEL 9 must be configured to disable the Asynchronous Transfer Mode kernel module. - Fail
- o V-257805 - RHEL 9 must be configured to disable the Controller Area Network kernel module. - Fail
- o V-257806 - RHEL 9 must be configured to disable the FireWire kernel module. - Fail
- o V-257807 - RHEL 9 must disable the Stream Control Transmission Protocol (SCTP) kernel module. - Fail
- o V-257808 - RHEL 9 must disable the Transparent Inter Process Communication (TIPC) kernel module. - Fail
- o V-257809 - RHEL 9 must implement address space layout randomization (ASLR) to protect its memory from unauthorized code execution. - Pass
- o V-257810 - RHEL 9 must disable access to network bpf system call from nonprivileged processes. - Fail
- o V-257811 - RHEL 9 must restrict usage of ptrace to descendant processes. - Fail
- o V-257812 - RHEL 9 must disable core dump backtraces. - Fail
- o V-257813 - RHEL 9 must disable storing core dumps. - Fail
- o V-257814 - RHEL 9 must disable core dumps for all users. - Fail
- o V-257815 - RHEL 9 must disable acquiring, saving, and processing core dumps. - Fail
- o V-257816 - RHEL 9 must disable the use of user namespaces. - Fail
- o V-257817 - RHEL 9 must implement nonexecutable data to protect its memory from unauthorized code execution. - Pass
- o V-257818 - The kdump service on RHEL 9 must be disabled. - Fail
- o V-257819 - RHEL 9 must ensure cryptographic verification of vendor software packages. - Fail
- o V-257823 - RHEL 9 must be configured so that the cryptographic hashes of system files match vendor values. - Pass
- o V-257825 - RHEL 9 subscription-manager package must be installed. - Fail
- o V-257827 - RHEL 9 must not have the sendmail package installed. - Pass
- o V-257828 - RHEL 9 must not have the nfs-utils package installed. - Pass
- o V-257829 - RHEL 9 must not have the ypserv package installed. - Pass
- o V-257830 - RHEL 9 must not install packages from the Extra Packages for Enterprise Linux (EPEL) repository. - Pass

Activities SCC Report Viewer Mar 9 23:21

SCC Report Viewer [file:///home/adones/SCC/Sessions/2026-03-09_231903/Results/SCAP/LOCALHOST_SCC-5.14_2026-03-09_231903_All-Settings_RHEL_9_STIG-002.007.011.html] x

Navigation Search

Back Forward Reload Q Search Match Case 0 of 0

- o V-257808 - RHEL 9 must disable the Transparent Inter Process Communication (TIPC) kernel module. - Not Selected
- o V-257809 - RHEL 9 must implement address space layout randomization (ASLR) to protect its memory from unauthorized code execution. - Not Selected
- o V-257810 - RHEL 9 must disable access to network bpf system call from nonprivileged processes. - Not Selected
- o V-257811 - RHEL 9 must restrict usage of ptrace to descendant processes. - Not Selected
- o V-257812 - RHEL 9 must disable core dump backtraces. - Not Selected
- o V-257813 - RHEL 9 must disable storing core dumps. - Not Selected
- o V-257814 - RHEL 9 must disable core dumps for all users. - Not Selected
- o V-257815 - RHEL 9 must disable acquiring, saving, and processing core dumps. - Not Selected
- o V-257816 - RHEL 9 must disable the use of user namespaces. - Not Selected
- o V-257817 - RHEL 9 must implement nonexecutable data to protect its memory from unauthorized code execution. - Not Selected
- o V-257818 - The kdump service on RHEL 9 must be disabled. - Not Selected
- o V-257819 - RHEL 9 must ensure cryptographic verification of vendor software packages. - Not Selected
- o V-257823 - RHEL 9 must be configured so that the cryptographic hashes of system files match vendor values. - Not Selected
- o V-257825 - RHEL 9 subscription-manager package must be installed. - Not Selected
- o V-257827 - RHEL 9 must not have the sendmail package installed. - Not Selected
- o V-257828 - RHEL 9 must not have the nfs-utils package installed. - Not Selected
- o V-257829 - RHEL 9 must not have the ypserv package installed. - Not Selected
- o V-257830 - RHEL 9 must not install packages from the Extra Packages for Enterprise Linux (EPEL) repository. - Not Selected
- o V-257831 - RHEL 9 must not have the telnet-server package installed. - Not Selected
- o V-257832 - RHEL 9 must not have the gssproxy package installed. - Not Selected
- o V-257833 - RHEL 9 must not have the iputils package installed. - Not Selected
- o V-257834 - RHEL 9 must not have the tuned package installed. - Not Selected
- o V-257836 - RHEL 9 must not have the quagga package installed. - Not Selected
- o V-257837 - A graphical display manager must not be installed on RHEL 9 unless approved. - Not Selected
- o V-257838 - RHEL 9 must have the openssl-pkcs11 package installed. - Pass
- o V-257839 - RHEL 9 must have the gnutils package installed. - Pass
- o V-257840 - RHEL 9 must have the nss-tools package installed. - Pass
- o V-257841 - RHEL 9 must have the rng-tools package installed. - Pass
- o V-257842 - RHEL 9 must have the s-nail package installed. - Pass
- o V-257843 - A separate RHEL 9 file system must be used for user home directories (such as /home or an equivalent). - Not Selected
- o V-257844 - RHEL 9 must use a separate file system for /tmp. - Not Selected
- o V-257848 - RHEL 9 must use a separate file system for /var/tmp. - Not Selected
- o V-257849 - RHEL 9 file system automount function must be disabled unless required. - Not Selected
- o V-257850 - RHEL 9 must prevent device files from being interpreted on file systems that contain user home directories. - Not Selected
- o V-257851 - RHEL 9 must prevent files with the setuid and setgid bit set from being executed on file systems that contain user home directories. - Not Selected
- o V-257852 - RHEL 9 must prevent code from being executed on file systems that contain user home directories. - Not Selected
- o V-257854 - RHEL 9 must prevent special devices on file systems that are imported via Network File System (NFS). - Not Selected
- o V-257855 - RHEL 9 must prevent code from being executed on file systems that are imported via Network File System (NFS). - Not Selected
- o V-257856 - RHEL 9 must prevent files with the setuid and setgid bit set from being executed on file systems that are imported via Network File System (NFS). - Not Selected
- o V-257860 - RHEL 9 must mount /boot with the noexec option. - Not Selected
- o V-257861 - RHEL 9 must prevent files with the setuid and setgid bit set from being executed on the /boot directory. - Not Selected
- o V-257862 - RHEL 9 must prevent files with the setuid and setgid bit set from being executed on the /boot/efi directory. - Not Selected
- o V-257863 - RHEL 9 must mount /dev/shm with the noexec option. - Not Selected
- o V-257864 - RHEL 9 must mount /dev/shm with the noexec option. - Not Selected
- o V-257865 - RHEL 9 must mount /dev/shm with the noexec option. - Not Selected
- o V-257866 - RHEL 9 must mount /tmp with the noexec option. - Not Selected
- o V-257867 - RHEL 9 must mount /tmp with the noexec option. - Not Selected
- o V-257868 - RHEL 9 must mount /tmp with the noexec option. - Not Selected
- o V-257869 - RHEL 9 must mount /var with the noexec option. - Not Selected

LOW SEVERITY (CAT III)

Results: Low Severity (CAT III)

Automated Checks

- o V-257782 - RHEL 9 must enable the hardware random number generator entropy gatherer service. - Fail
- o V-257795 - RHEL 9 must enable mitigations against processor-based vulnerabilities. - Fail
- o V-257796 - RHEL 9 must enable auditing of processes that start prior to the audit daemon. - Fail
- o V-257824 - RHEL 9 must remove all software components after updated versions have been installed. - Pass
- o V-257845 - RHEL 9 must use a separate file system for /var. - Fail
- o V-257846 - RHEL 9 must use a separate file system for /var/log. - Fail
- o V-257847 - RHEL 9 must use a separate file system for the system audit data path. - Fail
- o V-257880 - RHEL 9 must disable mounting of cramfs. - Fail
- o V-257946 - RHEL 9 must disable the chrony daemon from acting as a server. - Fail
- o V-257947 - RHEL 9 must disable network management of the chrony daemon. - Fail
- o V-258037 - RHEL 9 must enable Linux audit logging for the USBGuard daemon. - Fail
- o V-258069 - RHEL 9 must limit the number of concurrent sessions to ten for all accounts and/or account types. - Fail
- o V-258173 - RHEL 9 must allocate an audit_backlog_limit of sufficient size to capture processes that start prior to the audit daemon. - Fail

Manual Checks

- o V-258138 - RHEL 9 must be configured so that the file integrity tool verifies Access Control Lists (ACLs). - Not Checked
- o V-258139 - RHEL 9 must be configured so that the file integrity tool verifies extended attributes. - Not Checked

Detailed Results: High Severity (CAT I)

SCC Report Viewer [file:///home/adones/SCC/Sessions/2026-03-09_231903/Results/SCAP/LOCALHOST_SCC-5.14_2026-03-09_231903_All-Settings_RHEL_9_STIG-002.007.011.html] x

Navigation

Search

Back Forward Reload Q Search < > Match Case 0 of 0

- o V-258127 - RHEL 9, for PKI-based authentication, must enforce authorized access to the corresponding private key. - Not Selected
- o V-258132 - RHEL 9 must map the authenticated identity to the user or group account for PKI-based authentication. - Not Selected
- o V-258134 - RHEL 9 must have the AIDE package installed. - Not Selected
- o V-258135 - RHEL 9 must routinely check the baseline configuration for unauthorized changes and notify the system administrator when anomalies in the operation of any security functions are discovered. - Not Selected
- o V-258136 - RHEL 9 must use a file integrity tool that is configured to use FIPS 140-3-approved cryptographic hashes for validating file contents and directories. - Not Selected
- o V-258150 - RHEL 9 must use cron logging. - Not Selected
- o V-270174 - RHEL 9 must display the Standard Mandatory DOD Notice and Consent Banner before granting local or remote access to the system via a graphical user login. - Not Selected

Results: Low Severity (CAT III)

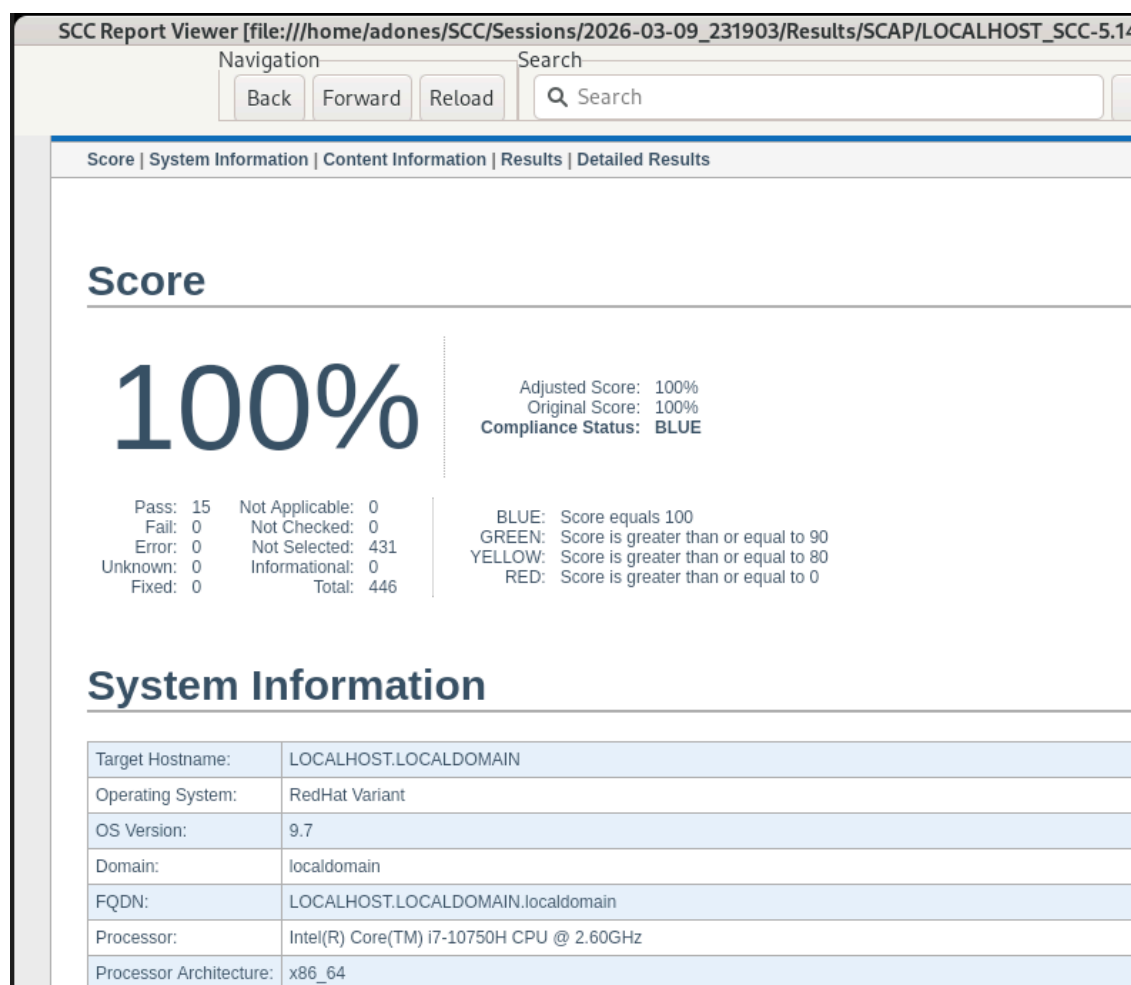
Automated Checks

- o V-257782 - RHEL 9 must enable the hardware random number generator entropy gatherer service. - Not Selected
- o V-257795 - RHEL 9 must enable mitigations against processor-based vulnerabilities. - Pass
- o V-257796 - RHEL 9 must enable auditing of processes that start prior to the audit daemon. - Pass
- o V-257824 - RHEL 9 must remove all software components after updated versions have been installed. - Not Selected
- o V-257845 - RHEL 9 must use a separate file system for /var. - Not Selected
- o V-257846 - RHEL 9 must use a separate file system for /var/log. - Not Selected
- o V-257847 - RHEL 9 must use a separate file system for the system audit data path. - Not Selected
- o V-257880 - RHEL 9 must disable mounting of cramfs. - Pass
- o V-257946 - RHEL 9 must disable the chrony daemon from acting as a server. - Pass
- o V-257947 - RHEL 9 must disable network management of the chrony daemon. - Pass
- o V-258037 - RHEL 9 must enable Linux audit logging for the USBGuard daemon. - Not Selected
- o V-258069 - RHEL 9 must limit the number of concurrent sessions to ten for all accounts and/or account types. - Not Selected
- o V-258173 - RHEL 9 must allocate an audit_backlog_limit of sufficient size to capture processes that start prior to the audit daemon. - Not Selected

Manual Checks

- o V-258138 - RHEL 9 must be configured so that the file integrity tool verifies Access Control Lists (ACLs). - Not Selected
- o V-258139 - RHEL 9 must be configured so that the file integrity tool verifies extended attributes. - Not Selected

Detailed Results: High Severity (CAT I)



Through this activity, I learned how to use the DISA STIG guidelines and the SCAP Compliance Checker (SCC) tool to find and fix security issues in a Linux system. At first, some of the findings were confusing, but by carefully reading the check text and fix instructions, I was able to understand what each rule was asking and how to apply the correct changes. For the CAT I findings, I worked on rules 258018, 257984, 258094, 258230, and 258236, which mainly involved improving system security settings like authentication and preventing insecure configurations. For CAT II, I selected 257838, 257839, 257840, 257841, and 257842, which helped me learn more about securing system services and improving overall system compliance. For CAT III, I worked on 257880, 257946, 257947, 257795, and 257796, where I disabled unused modules and configured kernel settings like enabling auditing and processor security mitigations. During this process I used different Linux commands, edited configuration files, and verified my changes by running scans again. After completing the remediation steps and rescanning the system, I was able to reach 100% compliance, as shown in the screenshot. Overall, this activity helped me better understand how system hardening works and how important it is to properly configure systems to reduce security risks.